LAPORAN AUDIT KEAMANAN APLIKASI — RAHASIA

finance-service
Go Backend Security Audit

Full endpoint scan — static code review

Tanggal audit	2026-10-25
Target	Repository finance-service (branch develop, working tree lokal)
Framework	Go 1.25, Fiber v2.52.9, GORM (PostgreSQL), golang-jwt v4 & v5, excelize, S3-compatible storage
Metode	Analisis statis source code & git history, go vet, go test, secret scan lokal
Dynamic testing	Tidak dilakukan (lihat Batasan)
Total endpoint	86
Total temuan	19 (1 Critical, 6 High, 6 Medium, 5 Low, 1 Informational)

Dokumen ini memuat detail kerentanan yang belum diperbaiki. Bagikan hanya kepada tim yang berwenang. Tidak ada secret, password, atau token yang ditampilkan.

1. Ruang lingkup dan batasan

- **Dalam lingkup:** seluruh source Go pada repository (cmd/, infrastructure/, presentation/, usecase/, domain/), Dockerfile, .gitlab-ci.yml (hanya include template), dan git history untuk file konfigurasi.
- **Di luar lingkup / tidak dapat diverifikasi:** template CI eksternal (al-azhar-iac/cicd-template), konfigurasi gateway/ingress (rate limit, TLS), skema & privilege database aktual, service penerbit JWT (account service), definisi view `finance.v_penerimaan_list`, konfigurasi bucket storage.
- **Tidak ada dynamic testing:** database lokal (port 5433) tidak aktif dan tidak ada persetujuan menguji server dev/staging. Tidak ada request yang dikirim ke environment mana pun selama audit.
- **Kedalaman:** 35 dari 86 endpoint ditelusuri sampai query SQL. Sisanya diperiksa pada level route, middleware, dan pola handler/repository yang sama. Status "tidak ada temuan spesifik" **bukan** jaminan endpoint aman.
- **Keterbatasan tool:** govulncheck & gosec tidak terpasang; staticcheck tidak kompatibel dengan versi Go modul (detail di bagian 7).

2. Executive summary

1	6	6	5	1
Critical	High	Medium	Low	Informational

Kontrol keamanan finance-service saat ini bergantung hampir sepenuhnya pada **keabsahan token JWT**. Tiga masalah membuat kontrol itu mudah ditembus atau tidak relevan:

1. **Secret penandatangan JWT pernah di-commit ke git (FIN-01, Critical)** dan identik dengan konfigurasi lokal saat ini. Siapa pun dengan akses baca repo dapat membuat token untuk user dan role apa pun.
2. **Dua endpoint laporan tidak memakai autentikasi sama sekali (FIN-02, High)** — laporan realisasi anggaran seluruh unit dan ekspornya dapat diunduh anonim, dan pesan error database ikut terekspos (FIN-10).
3. **SQL injection melalui parameter pengurutan (FIN-03, High)** pada list vendor, direktorat, dan sub-direktorat.

Di luar itu, aplikasi **tidak memiliki otorisasi berbasis role maupun kepemilikan data** selain menu /settings (FIN-04, FIN-05): pembatasan data per subdirektorat ditentukan oleh parameter dari klien, dan setiap user login dapat menyetujui, mencairkan, atau menghapus data keuangan. Beberapa alur keuangan juga dapat dimanipulasi (FIN-06 persetujuan RAPB tanpa state machine; FIN-07 nominal & bukti transfer APB dapat diisi bebas; FIN-08 status penerimaan ditentukan klien).

Rekomendasi utama: rotasi seluruh secret yang bocor dan tutup /laporan (P0, hari ini), perbaiki ORDER BY (P0), lalu bangun matriks role x aksi dan scope data dari sisi server (P1).

3. Ringkasan temuan

ID	Judul	Severity	Confidence	Prioritas	CWE
FIN-01	JWT signing secret & kredensial lain pernah di-commit ke git dan masih dipakai	Critical	High	P0	CWE-798 / CWE-540
FIN-02	Endpoint laporan realisasi anggaran tanpa autentikasi	High	Confirmed	P0	CWE-306
FIN-03	SQL injection pada parameter sortColumn/sortOrder (ORDER BY)	High	Confirmed	P0	CWE-89
FIN-04	Tidak ada otorisasi berbasis role (function-level) selain /settings	High	Confirmed	P1	CWE-285 / CWE-862
FIN-05	Pembatasan data per subdirektorat ditentukan oleh parameter klien (BOLA/IDOR)	High	Confirmed	P1	CWE-639
FIN-06	Persetujuan kegiatan (RAPB) tanpa validasi transisi status dan tanpa row lock	High	High	P1	CWE-841 / CWE-362
FIN-07	Mass assignment pada update APB: nominal pencairan dan URL dokumen dapat diisi bebas	High	Confirmed	P1	CWE-915 / CWE-840
FIN-08	Status penerimaan ditentukan klien (dapat langsung 'settled')	Medium	Medium	P2	CWE-840
FIN-09	Hard delete data keuangan tanpa cek status dan tanpa audit trail	Medium	High	P2	CWE-840 / CWE-778
FIN-10	Pesan error internal/database dikembalikan ke klien	Medium	Confirmed	P2	CWE-209
FIN-11	Pencabutan token (blacklist) fail-open saat Redis tidak tersedia	Medium	Confirmed	P2	CWE-636
FIN-12	Validasi JWT kurang ketat (algoritma, iss/aud, exp wajib) dan parsing ganda v4/v5	Low	High	P3	CWE-347 / CWE-613
FIN-13	Potensi resource exhaustion: limit tanpa batas atas, decode gambar tanpa batas dimensi, tanpa rate limit	Medium	Medium	P2	CWE-770 / CWE-400
FIN-14	Secret di-bake ke image container dan token GitLab sebagai build-arg	Medium	High	P1	CWE-538 / CWE-214

FIN-15	Koneksi database dengan sslmode=disable hardcoded	Low	High	P3	CWE-319
FIN-16	CORS wildcard dan tidak ada security headers	Low	High	P3	CWE-942 / CWE-693
FIN-17	Ekstensi file upload (PDF) diambil dari nama file klien	Low	High	P3	CWE-434
FIN-18	Daftar pengguna (id, nama, role level) dapat diakses semua user login	Low	Medium	P3	CWE-200
FIN-19	Default Locals role_level_id=1 untuk semua request & route terdaftar dua kali	Informational	High	P3	CWE-1188

Confidence: **Confirmed** = dibuktikan langsung dari kode/respons; **High** = sangat mungkin, satu asumsi lingkungan belum diverifikasi; **Medium** = bergantung pada alur bisnis/konfigurasi yang tidak terdokumentasi.

4. Inventaris dan coverage endpoint

Total endpoint teridentifikasi	86 (85 route di route.go + 1 handler OPTIONS global)
Endpoint diperiksa (route, middleware, pola handler)	86 / 86
Endpoint ditelusuri mendalam sampai SQL	35
Endpoint dengan temuan spesifik endpoint	51
Endpoint tanpa temuan spesifik teridentifikasi	35 (tetap terdampak temuan global FIN-01, FIN-11, FIN-12 bila ber-Auth)
Endpoint tanpa autentikasi	3 (2 laporan + OPTIONS preflight)
Endpoint dengan otorisasi role	2 (/settings)
Belum dapat diverifikasi	Perilaku runtime seluruh endpoint (tanpa dynamic testing); endpoint berlabel "Route, middleware & pola handler" belum ditelusuri sampai SQL.

Coverage per HTTP method

Method	Total	Ditelusuri mendalam	Dengan temuan spesifik
DELETE	8	5	8
GET	54	19	21
OPTIONS	1	1	0
POST	10	4	10
PUT	13	6	12

Coverage per route group

Group	Middleware	Total	Method	Mendalam	Dengan temuan
/directorate	Auth(JWT)	5	POST 1, GET 2, PUT 1, DELETE 1	2	4
/sub-direktorat	Auth(JWT)	5	POST 1, GET 2, PUT 1, DELETE 1	2	4
/dropdown	Auth(JWT)	10	GET 10	1	1
/vendor	Auth(JWT)	6	POST 1, GET 3, PUT 1, DELETE 1	2	4
/coa	Auth(JWT)	7	POST 1, GET 4, PUT 1, DELETE 1	2	4
/kegiatan	Auth(JWT)	9	POST 2, GET 5, PUT 1, DELETE 1	5	7
/detail-kegiatan	Auth(JWT)	8	POST 1, GET 5, PUT 1, DELETE 1	1	4
/penerimaan	Auth(JWT)	6	POST 1, GET 3, PUT 1, DELETE 1	3	5
/pengeluaran	Auth(JWT)	7	GET 5, PUT 2	6	7
/apb	Auth(JWT)	6	POST 1, GET 3, PUT 2	5	6
/laporan	TIDAK ADA	2	GET 2	2	2
/generate	Auth(JWT)	2	GET 2	0	0
/kode-anggaran	Auth(JWT)	8	POST 1, GET 5, PUT 1, DELETE 1	1	3
/settings	Auth(JWT) + RequirePermission(MenuSettings)	2	GET 1, PUT 1	2	0
/m	Auth(JWT)	2	GET 2	0	0
(global)	recover, cors	1	OPTIONS 1	1	0

Inventaris endpoint lengkap

Method	Path	Handler	Auth	Otorisasi	Kedalaman	Temuan spesifik
POST	/directorate	directorateController.CreateHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
GET	/directorate	directorateController.GetAllHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-03, FIN-13

GET	/directorate/:id	directorateController.GetByUIDHandler	Ya	Tidak ada (semua user login)	Route/pola	-
PUT	/directorate/:id	directorateController.UpdateHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
DELETE	/directorate/:id	directorateController.DeleteHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-09
POST	/sub-direktorat	subDirectorateController.CreateHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-04
GET	/sub-direktorat	subDirectorateController.GetAllHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-03, FIN-13
GET	/sub-direktorat/:id	subDirectorateController.GetByUIDHandler	Ya	Tidak ada (semua user login)	Route/pola	-
PUT	/sub-direktorat/:id	subDirectorateController.UpdateHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
DELETE	/sub-direktorat/:id	subDirectorateController.DeleteHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
GET	/dropdown/directorate	directorateController.DropdownHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/dropdown/sub-direktorat	subDirectorateController.DropdownHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/dropdown/sub-direktorat-by-level	subDirectorateController.GetByLevelIDHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/dropdown/users	subDirectorateController.UserDropdownHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-18
GET	/dropdown/kegiatan	kegiatanController.GetKegiatanDropDown	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/dropdown/mkode-anggaran	masterKodeAnggaranController.DropdownHandlerMkodeAnggaran	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/dropdown/unit	kegiatanController.DropdownUnitHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/dropdown/:parent_uid/children	masterKodeAnggaranController.GetChildrenByParentUID	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/dropdown/status	kegiatanController.GetDropdownStatus	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/dropdown/vendor	apbContoller.GetVendorDropdown	Ya	Tidak ada (semua user login)	Route/pola	-
POST	/vendor	vendorController.CreateHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
GET	/vendor	vendorController.GetAllHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-03, FIN-13
GET	/vendor/categories	vendorController.GetCategoriesHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/vendor/:id	vendorController.GetByUIDHandler	Ya	Tidak ada (semua user login)	Route/pola	-
PUT	/vendor/:id	vendorController.UpdateHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
DELETE	/vendor/:id	vendorController.DeleteHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-09
POST	/coa/create	chartOfAccountController.CreateHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
GET	/coa	chartOfAccountController.GetAllHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-10
GET	/coa/dropdown	chartOfAccountController.DropdownHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/coa/parentDrop	chartOfAccountController.ParentDropdownHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/coa/detail/:id	chartOfAccountController.GetByUIDHandler	Ya	Tidak ada (semua user login)	Route/pola	-
PUT	/coa/update/:id	chartOfAccountController.UpdateHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
DELETE	/coa/delete/:id	chartOfAccountController.DeleteHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-09
POST	/kegiatan	kegiatanController.Create	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
GET	/kegiatan	kegiatanController.GetAll	Ya	Tidak ada (semua user login)	Mendalam	FIN-05
GET	/kegiatan/summary	kegiatanController.GetSummary	Ya	Tidak ada (semua user login)	Mendalam	FIN-05

GET	/kegiatan/dropdown/directorate	kegiatanController.GetDropdownDirectorate	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/kegiatan/dropdown/subdirectorate	kegiatanController.GetDropdownSubDirectorate	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/kegiatan/:id	kegiatanController.GetByID	Ya	Tidak ada (semua user login)	Mendalam	FIN-05, FIN-10
PUT	/kegiatan/:id	kegiatanController.Update	Ya	Tidak ada (semua user login)	Route/pola	FIN-04, FIN-05
DELETE	/kegiatan/:id	kegiatanController.Delete	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-05, FIN-09
POST	/kegiatan/status/:id	kegiatanController.StatusResponseHandler	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-06
POST	/detail-kegiatan	detailKegiatanController.CreateDetailSubdir	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
GET	/detail-kegiatan	detailKegiatanController.GetAllDetailKegiatan	Ya	Tidak ada (semua user login)	Mendalam	-
GET	/detail-kegiatan/dropdown/kegiatan	kegiatanController.GetDropdownKegiatan	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/detail-kegiatan/dropdown/SingleCoa	kegiatanController.GetDropdownChartOfAccount	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/detail-kegiatan/dropdown/status	kegiatanController.GetDropdownStatus	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/detail-kegiatan/:id	detailKegiatanController.GetDetailByID	Ya	Tidak ada (semua user login)	Route/pola	FIN-05
PUT	/detail-kegiatan/:id	detailKegiatanController.UpdateDetailSubdir	Ya	Tidak ada (semua user login)	Route/pola	FIN-04, FIN-05
DELETE	/detail-kegiatan/:id	detailKegiatanController.DeleteDetail	Ya	Tidak ada (semua user login)	Route/pola	FIN-04, FIN-05
POST	/penerimaan/create	penerimaanController.Create	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-08, FIN-13, FIN-17
GET	/penerimaan	penerimaanController.List	Ya	Tidak ada (semua user login)	Route/pola	FIN-05, FIN-13
GET	/penerimaan/card-line	penerimaanController.CardSummary	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/penerimaan/detail/:id	penerimaanController.Detail	Ya	Tidak ada (semua user login)	Route/pola	FIN-05
PUT	/penerimaan/update/:id	penerimaanController.Update	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-05, FIN-08, FIN-13, FIN-17
DELETE	/penerimaan/delete/:id	penerimaanController.Delete	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-05, FIN-09
GET	/pengeluaran	pengeluaranController.GetAllLpj	Ya	Tidak ada (semua user login)	Mendalam	FIN-05, FIN-13
GET	/pengeluaran/card-summary	pengeluaranController.CardSummary	Ya	Tidak ada (semua user login)	Mendalam	FIN-05
GET	/pengeluaran/trend	pengeluaranController.Trend	Ya	Tidak ada (semua user login)	Mendalam	FIN-05
GET	/pengeluaran/export	pengeluaranController.Export	Ya	Tidak ada (semua user login)	Mendalam	FIN-05
GET	/pengeluaran/:id	pengeluaranController.GetLpjByID	Ya	Tidak ada (semua user login)	Route/pola	FIN-05
PUT	/pengeluaran/:id	pengeluaranController.UpdateLpj	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-05, FIN-13, FIN-17
PUT	/pengeluaran/:id/status	pengeluaranController.StatusResponseLpj	Ya	Tidak ada (semua user login)	Mendalam	FIN-04
POST	/apb/create	apbContoller.Create	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-13, FIN-17
GET	/apb	apbContoller.List	Ya	Tidak ada (semua user login)	Mendalam	FIN-05, FIN-13
GET	/apb/summary	apbContoller.CardSummary	Ya	Tidak ada (semua user login)	Mendalam	FIN-05

GET	/apb/detail/:id	apbContoller.GetDetailByUID	Ya	Tidak ada (semua user login)	Route/pola	FIN-05
PUT	/apb/:id	apbContoller.Update	Ya	Tidak ada (semua user login)	Mendalam	FIN-04, FIN-05, FIN-07, FIN-13, FIN-17
PUT	/apb/:id/status	apbContoller.StatusResponse	Ya	Tidak ada (semua user login)	Mendalam	FIN-04
GET	/laporan/realisasi-anggaran	laporanController.RealisasiLaporan	TIDAK	Tidak ada	Mendalam	FIN-02, FIN-10
GET	/laporan/export	laporanController.ExportRealisasiAnggaran	TIDAK	Tidak ada	Mendalam	FIN-02, FIN-10
GET	/generate/subdirektorat-code	subDirectorateController.GenerateCodeHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/generate/coa-generate-code	chartOfAccountController.GenerateCodeHandler	Ya	Tidak ada (semua user login)	Route/pola	-
POST	/kode-anggaran/create	masterController.CreateKodeAnggaranHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
GET	/kode-anggaran/list-detail	masterKodeAnggaranController.ListByFiltersHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/kode-anggaran/parents	masterKodeAnggaranController.ParentsByLevelHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/kode-anggaran/next-code	masterKodeAnggaranController.NextKodeAnggaranHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/kode-anggaran/export	masterKodeAnggaranController.ExportKodeAnggaranCOAHandler	Ya	Tidak ada (semua user login)	Mendalam	-
GET	/kode-anggaran/detail/:id	masterController.GetKodeAnggaranByUIDHandler	Ya	Tidak ada (semua user login)	Route/pola	-
PUT	/kode-anggaran/update/:id	masterController.UpdateKodeAnggaranHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
DELETE	/kode-anggaran/delete/:id	masterController.DeleteKodeAnggaranHandler	Ya	Tidak ada (semua user login)	Route/pola	FIN-04
GET	/settings/change-settings	settingsController.GetSettingsHandler	Ya	RequirePermission(settings)	Mendalam	-
PUT	/settings/change-settings	settingsController.ChangeSettingsHandler	Ya	RequirePermission(settings)	Mendalam	-
GET	/m/kode-anggaran	masterController.GetKodeAnggaranHandler	Ya	Tidak ada (semua user login)	Route/pola	-
GET	/m/regions	regionController.ListRegionsHandler	Ya	Tidak ada (semua user login)	Route/pola	-
OPTIONS	/*	inline: SendStatus(200)	TIDAK (by design, preflight CORS)	-	Mendalam	-

Daftar lengkap dengan lokasi baris route: security-reports/endpoint-inventory.csv.

5. Detail temuan

FIN-01 — JWT signing secret & kredensial lain pernah di-commit ke git dan masih dipakai

Severity / Confidence	**Critical** High | Prioritas P0
Kategori	CWE-798 / CWE-540 — API2:2023 Broken Authentication; API8:2023 Security Misconfiguration
Lokasi	git history: commit 4289b65 (.env), 2a0ee3f & cea3141 (config/.env) — branch origin/develop
Endpoint terdampak	Semua endpoint ber-Auth(JWT) (83 endpoint)
Prasyarat	Akses baca ke repository (atau salinannya). Tidak perlu akun aplikasi. Belum diverifikasi apakah server dev/prod memakai secret yang sama dengan config lokal.
Dampak (C/I/A)	C: High — akses baca seluruh data keuangan. I: High — persetujuan/edit/hapus data sebagai user mana pun. A: Medium — penghapusan master data.

Bukti (disamarkan)

```
$ git log --all --oneline -- config/.env '*.env'
cea3141 Refactor configuration structure ...   (hapus config/.env)
2a0ee3f sub-directorate                        (rename .env -> config/.env)
4289b65 error depedencies                      (tambah .env, 50 baris)

Key di file historis (nilai TIDAK ditampilkan):
  JWT.SECRET   <non-empty, 31 char>  -> IDENTIK dgn config/.env lokal saat ini
  SECRET.KEY   <non-empty>           -> IDENTIK dgn config/.env lokal saat ini
  SMTP.PASSWORD<non-empty>           -> IDENTIK dgn config/.env lokal saat ini
  DB.PASSWORD / DB_READ.PASSWORD     -> berbeda dari config lokal saat ini
```

Skenario eksploitasi

Siapa pun yang punya akses baca repo (developer, mantan anggota tim, runner CI, mirror) mengambil JWT.SECRET dari commit 4289b65, lalu menandatangani token HS256 sendiri dengan user_id dan role_name bebas (mis. 'administrator'). middleware.Auth hanya memverifikasi tanda tangan, sehingga token palsu diterima di seluruh endpoint, termasuk /settings.

Rekomendasi

1) Rotasi JWT.SECRET, SECRET.KEY, SMTP password, dan DB password lama SEKARANG (anggap sudah bocor) — koordinasikan dengan service penerbit token karena secret dipakai bersama. 2) Simpan secret di secret manager / variabel CI masked, bukan file di repo. 3) Bersihkan history (git filter-repo / BFG) lalu force-push dengan koordinasi tim — rotasi tetap wajib karena clone lama masih menyimpan secret. 4) Tambahkan secret scanning (gitleaks) di pre-commit & CI.

Contoh perbaikan minimal

```
# .gitlab-ci.yml (contoh job tambahan)
secret-scan:
  image: zricethezav/gitleaks:latest
  script: [ "gitleaks detect --source . --redact --exit-code 1" ]
```

Test regresi

CI job gitleaks wajib hijau; test startup gagal bila JWT secret < 32 byte atau sama dengan nilai yang diketahui bocor (cek hash).

FIN-02 — Endpoint laporan realisasi anggaran tanpa autentikasi

Severity / Confidence	**High** Confirmed | Prioritas P0
Kategori	CWE-306 — API2:2023 Broken Authentication; API5:2023 BFLA
Lokasi	infrastructure/rest/route.go:121-123
Endpoint terdampak	GET /laporan/realisasi-anggaran; GET /laporan/export
Prasyarat	Akses jaringan ke service (melalui gateway/ingress). Tidak perlu token.
Dampak (C/I/A)	C: High — data anggaran & realisasi seluruh unit terbuka ke publik. I: None. A: Medium — query berat dapat dipanggil anonim tanpa rate limit.

Bukti (disamarkan)

```
app.Group("/laporan").                                // <- tanpa middleware.Auth
    Get("/realisasi-anggaran", laporanController.RealisasiLaporan).
    Get("/export", laporanController.ExportRealisasiAnggaran)

// grup lain:
app.Group("/apb", middleware.Auth(tokenService)). ...
```

Skenario eksploitasi

Request tanpa header Authorization ke GET /laporan/realisasi-anggaran?tahun=2026 (atau /laporan/export) mengembalikan laporan APB/RAPB seluruh direktorat beserta realisasinya. Query ini berat (CTE rekursif, tanpa LIMIT), sehingga request berulang tanpa autentikasi juga dapat membebani database.

Rekomendasi

Tambahkan middleware.Auth(tokenService) ke grup /laporan; bila laporan hanya untuk role tertentu, tambahkan RequirePermission. Tambahkan test yang memastikan semua route kecuali OPTIONS mengembalikan 401 tanpa token.

Contoh perbaikan minimal

```
app.Group("/laporan", middleware.Auth(tokenService)).
    Get("/realisasi-anggaran", laporanController.RealisasiLaporan).
    Get("/export", laporanController.ExportRealisasiAnggaran)
```

Test regresi

Test iterasi app.GetRoutes(): untuk setiap route non-OPTIONS, request tanpa Authorization harus 401.

FIN-03 — SQL injection pada parameter sortColumn/sortOrder (ORDER BY)

Severity / Confidence	**High** Confirmed | Prioritas P0
Kategori	CWE-89 — API8:2023 / OWASP A03:2021 Injection
Lokasi	domain/repository/vendor_repository.go:56; domain/repository/directorate_repository.go:97; domain/repository/sub_directorate_repository.go:87
Endpoint terdampak	GET /vendor; GET /directorate; GET /sub-direktorat
Prasyarat	Token JWT valid (role apa pun).
Dampak (C/I/A)	C: High — ekstraksi data di luar hak akses. I: Medium — tergantung privilege user DB (tidak diverifikasi). A: Medium — ekspresi berat (pg_sleep) dapat mengikat koneksi.

Bukti (disamarkan)

```
// controller (vendor_controller.go:53–54; directorate_controller.go:55–56; sub_directorate_controller.go:89–90)
sortColumn := strings.TrimSpace(ctx.Query("sortColumn"))
sortOrder  := strings.TrimSpace(ctx.Query("sortOrder"))
// usecase meneruskan apa adanya -> repository:
query = query.Order(sortColumn + " " + sortOrder)   // GORM tidak meng-escape string Order()
```

Skenario eksploitasi

User login mana pun mengirim sortColumn berisi ekspresi SQL, mis. (CASE WHEN (SELECT ...) THEN created_at ELSE vendor_name END), lalu menyimpulkan data dari urutan hasil (boolean-based blind). Koneksi DB yang sama dipakai untuk join ke schema account (account.users), sehingga data di luar schema finance kemungkinan juga terjangkau. (Tidak diuji dinamis.)

Rekomendasi

Gunakan allow-list kolom dan normalisasi arah (ASC/DESC) seperti yang sudah dilakukan di chart_of_account_repository.go & kegiatan_repository.go; atau clause.OrderByColumn dengan kolom yang divalidasi.

Contoh perbaikan minimal

```
allowed := map[string]string{"vendor_name": "vendor_name", "created_at": "created_at"}
col, ok := allowed[sortColumn]
if !ok { col = "created_at" }
dir := "DESC"
if strings.EqualFold(sortOrder, "asc") { dir = "ASC" }
query = query.Order(col + " " + dir)
```

Test regresi

Unit test repository/controller: sortColumn='vendor_name;--', '(select 1)', 'created_at desc, (case ...)' harus jatuh ke default; sortOrder selain asc/desc diabaikan.

FIN-04 — Tidak ada otorisasi berbasis role (function-level) selain /settings

Severity / Confidence	**High** Confirmed | Prioritas P1
Kategori	CWE-285 / CWE-862 — API5:2023 Broken Function Level Authorization
Lokasi	infrastructure/rest/route.go:31-145; presentation/middleware/permission.go (hanya dipakai di /settings)
Endpoint terdampak	POST /kegiatan/status/:id; PUT /apb/:id/status; PUT /pengeluaran/:id/status; PUT /apb/:id; DELETE /kegiatan/:id; DELETE /penerimaan/delete/:id; DELETE /vendor/:id; DELETE /directorate/:id; DELETE /sub-direktorat/:id; DELETE /coa/delete/:id; DELETE /kode-anggaran/delete/:id; DELETE /detail-kegiatan/:id; POST/PUT master data (directorate, sub-direktorat, vendor, coa, kode-anggaran)
Prasyarat	Token valid role apa pun.
Dampak (C/I/A)	C: Medium. I: High — persetujuan, pencairan, dan penghapusan data oleh role yang tidak berwenang. A: Medium — penghapusan master data.

Bukti (disamarkan)

```
$ grep -rn "claims.Role\|RoleID\|RoleLevel\|SchoolID" --include=*.go presentation usecase domain
presentation/middleware/permission.go:31:  if !IsAllowed(menuKey, claims.Role) {     // satu-satunya pemeriksaan role

// Contoh endpoint persetujuan — hanya cek token valid:
claims, err := middleware.Extract(ctx)        // apb_controller.go:443
resp, err := h.usecase.StatusResponse(ctx.UserContext(), id, input, &userID)
```

Skenario eksploitasi

User dengan role 'Maker'/keuangan memanggil PUT /apb/:id/status untuk memindahkan APB ke 'Sudah Dibayarkan', atau POST /kegiatan/status/:id dengan status Approved untuk menyetujui RAPB miliknya sendiri, atau DELETE master data — semua diterima karena hanya keabsahan token yang dicek.

Rekomendasi

Definisikan matriks role x aksi (maker, approver anggaran, approver pembayaran, admin) dan terapkan middleware.RequirePermission per route/aksi (map menuRoles yang sudah ada dapat diperluas). Untuk aksi persetujuan, cek juga di usecase (defense in depth) bahwa role pemanggil sesuai tahap workflow.

Contoh perbaikan minimal

```
// permission.go
var menuRoles = map[string][]string{
    MenuSettings:      {"administrator"},
    MenuApprovalRAPB:  {"administrator", "approver anggaran"},
    MenuApprovalBayar: {"administrator", "approver pembayaran"},
}
// route.go
app.Post("/kegiatan/status/:id", middleware.Auth(ts), middleware.RequirePermission(middleware.MenuApprovalRAPB),
kegiatanController.StatusResponseHandler)
```

Test regresi

Tabel test per route: token role X -> status 403/2xx sesuai matriks.

FIN-05 — Pembatasan data per subdirektorat ditentukan oleh parameter klien (BOLA/IDOR)

Severity / Confidence	**High** Confirmed | Prioritas P1
Kategori	CWE-639 — API1:2023 Broken Object Level Authorization
Lokasi	presentation/controller/kegiatan_controller.go (GetAll, GetSummary); apb_controller.go (applySubdirektoratFilter); pengeluaran_controller.go (parseFilter, GetAllLpj); domain/repository/kegiatan_repository.go:FindAll
Endpoint terdampak	GET /kegiatan; GET /kegiatan/summary; GET /kegiatan/:id; GET /apb; GET /apb/summary; GET /apb/detail/:id; GET /pengeluaran; GET /pengeluaran/:id; GET /pengeluaran/card-summary; GET /pengeluaran/trend; GET /pengeluaran/export; GET /penerimaan; GET /penerimaan/detail/:id; GET /detail-kegiatan/:id; PUT/DELETE berbasis :id
Prasyarat	Token valid. Untuk /:id perlu UUID objek (dapat diperoleh dari endpoint list).
Dampak (C/I/A)	C: High — data anggaran lintas unit. I: High — edit/hapus objek unit lain (dikombinasikan dengan FIN-04).

Bukti (disamarkan)

```
// kegiatan_repository.go — komentar FindAll:
// subdirektoratID: subdirektorat user (dari /me) ...; nil = tidak disaring.
subdirektoratUID, err := parseSubdirektoratID(ctx.Query("subdirektorat_id"))   // nilai dari query string klien
if subdirektoratID != nil { query = query.Where("(kegiatan.subdirektorat_id = ? OR kegiatan.upt_id = ?)", ...) }

// GetByID/Detail/Update/Delete: hanya WHERE uid = ? tanpa cek kepemilikan
```

Skenario eksploitasi

User subdirektorat A cukup menghapus parameter subdirektorat_id (atau mengganti dengan UUID subdirektorat B) untuk melihat seluruh RAPB/APB/LPJ unit lain. Dengan UUID objek (mis. dari list), user juga dapat membuka/mengubah/menghapus objek unit lain via /:id.

Rekomendasi

Ambil scope (subdirektorat/UPT user) dari sumber tepercaya di server (claim JWT atau lookup finance.user_subdirektorat berdasarkan user_id token), bukan dari query string. Hanya role admin/konsolidasi yang boleh tanpa filter. Terapkan scope yang sama di GetByID/Update/Delete (WHERE uid = ? AND subdirektorat_id IN (...)).

Contoh perbaikan minimal

```
func scopeFromToken(ctx *fiber.Ctx, repo UserScopeRepo) (*uuid.UUID, error) {
    claims, _ := middleware.Extract(ctx)
    if middleware.IsAllowed(middleware.MenuKonsolidasi, claims.Role) { return nil, nil } // admin: semua
    return repo.SubdirektoratOfUser(ctx.UserContext(), claims.UserID)               // abaikan query param
}
```

Test regresi

Test: user unit A + subdirektorat_id kosong -> hanya data unit A; user unit A akses GET /kegiatan/:id milik unit B -> 404/403.

FIN-06 — Persetujuan kegiatan (RAPB) tanpa validasi transisi status dan tanpa row lock

Severity / Confidence	**High** High | Prioritas P1
Kategori	CWE-841 / CWE-362 — API6:2023 Unrestricted Access to Sensitive Business Flows
Lokasi	domain/repository/kegiatan_repository.go:700-760; usecase/kegiatan_usecase.go:351-362
Endpoint terdampak	POST /kegiatan/status/:id
Prasyarat	Token valid (diperparah FIN-04: role apa pun).
Dampak (C/I/A)	I: High — budget terkunci tanpa alur persetujuan yang sah; duplikasi budget lock. C: None. A: Low.

Bukti (disamarkan)

```
if err := tx.Where("uid = ?", kegiatanUID).First(&kegiatan).Error; ...   // tanpa FOR UPDATE
tx.Model(&entity.Kegiatan{}).Where("uid = ?", kegiatanUID).
    Updates(map[string]interface{}{"status": int(input.Status), "notes": input.Notes})  // tanpa cek status lama
if input.Status == dto.StatusApproved { ... tx.Create(&budgetLock) ... }
// usecase: if userID == uuid.Nil { userID = uuid.MustParse("00000000-...-000000000001") }
```

Skenario eksploitasi

Kegiatan yang sudah Reject dapat langsung diubah menjadi Approved; kegiatan Approved dapat di-approve ulang; pembuat kegiatan dapat menyetujui kegiatannya sendiri (tidak ada cek approver != pembuat — tidak ditemukan pada kode yang ditelusuri). Dua request approve paralel dapat sama-sama lolos cek 'budget lock belum ada' (tanpa row lock / unique constraint terverifikasi).

Rekomendasi

Implementasikan state machine seperti di apbRepository.StatusResponse: SELECT ... FOR UPDATE, validasi status asal -> tujuan, tolak bila approver == pembuat, dan pasang unique constraint budget_lock(kegiatan_id). Hapus fallback user ID hardcoded; tolak request bila user tidak valid.

Contoh perbaikan minimal

```
if err := tx.Clauses(clause.Locking{Strength: "UPDATE"}).Where("uid = ?", id).First(&k).Error; err != nil { return err }
if !allowedTransition[dto.StatusMaster(k.Status)][input.Status] { return ErrKegiatanStatusConflict }
if k.CreatedBy == userID { return ErrSelfApproval }
```

Test regresi

Test: Reject->Approved ditolak; Approved->Approved ditolak; self-approve ditolak; 2 goroutine approve bersamaan -> 1 budget_lock.

FIN-07 — Mass assignment pada update APB: nominal pencairan dan URL dokumen dapat diisi bebas

Severity / Confidence	**High** Confirmed | Prioritas P1
Kategori	CWE-915 / CWE-840 — API3:2023 Broken Object Property Level Authorization
Lokasi	domain/dto/apb_summary.go:80-88 (ApbUpdate); presentation/controller/apb_controller.go:380-405; domain/repository/apb_repository.go:499-570
Endpoint terdampak	PUT /apb/:id
Prasyarat	Token valid (role apa pun, lihat FIN-04).
Dampak (C/I/A)	I: High — manipulasi nominal dan bukti keuangan, bypass alur upload. C: Low — tautan phishing ke approver.

Bukti (disamarkan)

```
type ApbUpdate struct {
    JumlahDisetujui *float64 `form:"jumlah_disetujui"`
    JumlahDicairkan *float64 `form:"jumlah_dicairkan"`
    DokumenMemo   string `form:"dokumen_memo"`     // teks bebas dari form
    BuktiTransfer string `form:"bukti_transfer"`   // teks bebas dari form
}
if memoURL != "" { input.DokumenMemo = memoURL }   // jika tidak upload file, nilai form tetap dipakai
// repository: updates["jumlah_dicairkan"] = *input.JumlahDicairkan  (tanpa cek status/role/nilai negatif)
// isMemoUpload := input.DokumenMemo != ""  -> Belum Diajukan -> Dalam Proses
// isBuktiUpload := input.BuktiTransfer != "" -> Sudah Dibayarkan -> Belum LPJ
```

Skenario eksploitasi

User mengirim PUT /apb/:id dengan field teks bukti_transfer=https://contoh.invalid/x.pdf tanpa file: status berpindah ke 'Belum LPJ' tanpa bukti transfer asli, dan approver melihat tautan eksternal sebagai bukti. User juga dapat mengubah jumlah_dicairkan (termasuk negatif) setelah dana dicairkan, sehingga laporan realisasi tidak lagi sesuai.

Rekomendasi

Pisahkan DTO input dari kolom tersimpan: jangan bind dokumen_memo/bukti_transfer dari body (tag form:"-"); URL hanya dari processFileUpload. Batasi perubahan jumlah_* ke tahap & role tertentu, validasi >= 0 dan <= jumlah_diminta/disetujui.

Contoh perbaikan minimal

```
type ApbUpdate struct {
    ...
    DokumenMemo   string `json:"-" form:"-"`
    BuktiTransfer string `json:"-" form:"-"`
}
if input.JumlahDicairkan != nil && (*input.JumlahDicairkan < 0 || current.Status != int(dto.StatusdalamAntrianDibayarkan)) {
    return ErrApbStatusConflict
}
```

Test regresi

Test: PUT tanpa file tapi dengan field bukti_transfer -> status tidak berubah, URL tidak tersimpan; jumlah_dicairkan negatif -> 400; ubah nominal setelah Sudah Dibayarkan -> 409.

FIN-08 — Status penerimaan ditentukan klien (dapat langsung 'settled')

Severity / Confidence	**Medium** Medium | Prioritas P2
Kategori	CWE-840 — API6:2023 Unrestricted Access to Sensitive Business Flows
Lokasi	presentation/controller/penerimaan_controller.go:86; usecase/penerimaan_usecase.go:90-93
Endpoint terdampak	POST /penerimaan/create; PUT /penerimaan/update/:id
Prasyarat	Token valid.
Dampak (C/I/A)	I: Medium — angka realisasi penerimaan dapat dimanipulasi. Confidence Medium karena alur bisnis penerimaan yang diinginkan tidak terdokumentasi di repo.

Bukti (disamarkan)

```
Status: strings.TrimSpace(ctx.FormValue("status")),   // controller
status := payload.Status; if status == "" { status = "draft" }   // usecase, tanpa allow-list/alur
// realisasi_anggaran_repository.go: realisasi penerimaan = SUM(jumlah) FILTER (WHERE status = 'settled')
```

Skenario eksploitasi

User membuat penerimaan dengan status=settled sehingga langsung terhitung sebagai realisasi di laporan RAPB, tanpa proses verifikasi. Nilai status sembarang (mis. 'xyz') juga diterima.

Rekomendasi

Allow-list nilai status; status 'settled' hanya lewat aksi verifikasi terpisah oleh role berwenang; create selalu 'draft'.

Contoh perbaikan minimal

```
if payload.Status != "" && payload.Status != "draft" {
    return nil, errors.New("status hanya dapat diubah melalui proses verifikasi")
}
```

Test regresi

Test: create dengan status=settled -> tersimpan draft atau 400; status tidak dikenal -> 400.

FIN-09 — Hard delete data keuangan tanpa cek status dan tanpa audit trail

Severity / Confidence	**Medium** High | Prioritas P2
Kategori	CWE-840 / CWE-778 — API6:2023; A09:2021 Logging & Monitoring Failures
Lokasi	usecase/kegiatan_usecase.go:260-266; domain/repository/kegiatan_repository.go:484-500; penerimaan_repository.go:215; vendor_repository.go:82; directorate_repository.go:121; chart_of_account_repository.go:40
Endpoint terdampak	DELETE /kegiatan/:id; DELETE /penerimaan/delete/:id; DELETE /vendor/:id; DELETE /directorate/:id; DELETE /coa/delete/:id
Prasyarat	Token valid (role apa pun, lihat FIN-04).
Dampak (C/I/A)	I: High pada data keuangan; tidak ada jejak untuk investigasi. A: Medium — kehilangan data.

Bukti (disamarkan)

```
func (u *kegiatanUseCase) Delete(...) error {
    _, err := u.repo.FindByID(ctx, kegiatanUID)      // hanya cek ada
    return u.repo.Delete(ctx, kegiatanUID)           // hapus detail, budget_lock, kegiatan
}
return r.db.WithContext(ctx).Where("uid = ?", uid).Delete(&entity.Penerimaan{}).Error   // hard delete
```

Skenario eksploitasi

Kegiatan yang sudah Approved (punya budget lock, mungkin sudah direferensikan APB/LPJ) dapat dihapus beserta budget lock-nya. Penerimaan yang sudah settled dapat dihapus permanen tanpa jejak siapa yang menghapus.

Rekomendasi

Larang delete untuk status di luar draft/revisi; gunakan soft delete (deleted_at, deleted_by) untuk data keuangan; catat audit log (user, waktu, objek, nilai sebelum).

Contoh perbaikan minimal

```
if k.Status != int(dto.StatusDraft) { return ErrKegiatanTidakDapatDihapus }
```

Test regresi

Test: DELETE kegiatan Approved -> 409; DELETE penerimaan -> baris tetap ada dengan deleted_at & deleted_by.

FIN-10 — Pesan error internal/database dikembalikan ke klien

Severity / Confidence	**Medium** Confirmed | Prioritas P2
Kategori	CWE-209 — API8:2023 Security Misconfiguration
Lokasi	88 lokasi err.Error() di presentation/controller (mis. realisasi_anggaran_controller.go:32, chart_of_account_controller.go:60, kegiatan_controller.go GetByID)
Endpoint terdampak	GET /laporan/realisasi-anggaran (anonim); GET /laporan/export (anonim); GET /coa; GET /kegiatan/:id; dan endpoint lain yang memakai err.Error()
Prasyarat	Tidak ada untuk /laporan; token valid untuk lainnya.
Dampak (C/I/A)	C: Low-Medium — informasi internal. Severity dinaikkan ke Medium karena terekspos tanpa autentikasi (FIN-02).

Bukti (disamarkan)

```
return ctx.Status(500).JSON(fiber.Map{"status": "error", "message": err.Error()})

// Teramati di environment dev (screenshot dari user saat sesi ini, endpoint tanpa auth):
{"message":"ERROR: operator does not exist: character varying = uuid (SQLSTATE 42883)","status":"error"}
```

Skenario eksploitasi

Penyerang memicu error (parameter tak valid) untuk mempelajari nama tabel/kolom/tipe, versi driver, dan struktur query — mempermudah eksploitasi FIN-03. Pada /laporan ini dapat dilakukan tanpa login.

Rekomendasi

Log error lengkap di server (dengan trace_id), kembalikan pesan generik + trace_id ke klien. Sentralisasi di error handler Fiber.

Contoh perbaikan minimal

```
log.Printf("[laporan] gagal: %v", err)
return ctx.Status(500).JSON(fiber.Map{"status": "error", "message": "Terjadi kesalahan pada server"})
```

Test regresi

Test: paksa repository mengembalikan error SQL -> body respons tidak mengandung 'SQLSTATE' atau nama tabel.

FIN-11 — Pencabutan token (blacklist) fail-open saat Redis tidak tersedia

Severity / Confidence	**Medium** Confirmed | Prioritas P2
Kategori	CWE-636 — API2:2023 Broken Authentication
Lokasi	infrastructure/security/token.go:26-33; cmd/main.go (Redis init hanya warning)
Endpoint terdampak	Semua endpoint ber-Auth(JWT) (83 endpoint)
Prasyarat	Memiliki token yang sudah di-logout + Redis tidak tersedia.
Dampak (C/I/A)	C/I: Medium — sesi yang dicabut tetap berlaku.

Bukti (disamarkan)

```
func (s *Service) IsBlacklisted(token string) bool {
    if s.redis == nil { return false }                 // Redis mati -> semua token dianggap aktif
    val, err := s.redis.Get(ctx, "blacklist:"+token)
    return err == nil && val == "true"                 // error koneksi -> tidak di-blacklist
}
// main.go: log.Printf("[WARNING] Gagal inisialisasi Redis (dilompati untuk testing): %v", err)
```

Skenario eksploitasi

Token yang sudah logout (di-blacklist) tetap dapat dipakai sampai kedaluwarsa bila Redis down saat startup atau error saat request.

Rekomendasi

Di environment non-test, gagal startup bila Redis tidak bisa diinisialisasi; saat error Redis per request, tolak (fail-closed) atau batasi dengan TTL token pendek. Bedakan redis.Nil (tidak ada key) dari error koneksi.

Contoh perbaikan minimal

```
val, err := s.redis.Get(ctx, "blacklist:"+token)
if errors.Is(err, goredis.Nil) { return false }
if err != nil { return true } // fail-closed
```

Test regresi

Test dengan mock Redis error -> Auth mengembalikan 401/503.

FIN-12 — Validasi JWT kurang ketat (algoritma, iss/aud, exp wajib) dan parsing ganda v4/v5

Severity / Confidence	**Low** High | Prioritas P3
Kategori	CWE-347 / CWE-613 — API2:2023 Broken Authentication
Lokasi	presentation/middleware/auth.go:44-49 (jwt/v4); infrastructure/security/token.go:39-42 (jwt/v5)
Endpoint terdampak	Semua endpoint ber-Auth(JWT) (83 endpoint)
Prasyarat	Kemampuan memperoleh token dari service lain dengan secret sama, atau token tanpa exp.
Dampak (C/I/A)	C/I: Low secara mandiri; menjadi signifikan bila digabung FIN-01.

Bukti (disamarkan)

```
token, err := jwt.Parse(tokenStr, func(t *jwt.Token) (interface{}, error) {
    return service.SecretKey(), nil          // tidak memeriksa t.Method / alg
})
// tidak ada WithValidMethods, WithIssuer, WithAudience, WithExpirationRequired
```

Skenario eksploitasi

Token tanpa klaim exp diterima tanpa batas waktu (golang-jwt hanya memvalidasi exp bila ada). Tidak ada pembatasan issuer/audience sehingga token yang ditandatangani dengan secret yang sama untuk service lain juga diterima. alg 'none' dan RS/HS confusion tidak dapat dieksploitasi pada versi library ini (diverifikasi dari perilaku library, bukan pengujian).

Rekomendasi

Gunakan satu library (jwt/v5) dan parser dengan jwt.WithValidMethods([]string{"HS256"}), jwt.WithExpirationRequired(), jwt.WithIssuer(...), jwt.WithAudience(...). Parse sekali, simpan claims di Locals.

Contoh perbaikan minimal

```
parser := jwt.NewParser(jwt.WithValidMethods([]string{"HS256"}), jwt.WithExpirationRequired(),
    jwt.WithIssuer("account-service"), jwt.WithAudience("finance-service"))
token, err := parser.Parse(tokenStr, keyFunc)
```

Test regresi

Test: token tanpa exp -> 401; alg HS512/none -> 401; iss/aud salah -> 401.

FIN-13 — Potensi resource exhaustion: limit tanpa batas atas, decode gambar tanpa batas dimensi, tanpa rate limit

Severity / Confidence	**Medium** Medium | Prioritas P2
Kategori	CWE-770 / CWE-400 — API4:2023 Unrestricted Resource Consumption
Lokasi	vendor_controller.go:43, directorate_controller.go:45, sub_directorate_controller.go:79, apb_controller.go:241, pengeluaran_controller.go:221, penerimaan_controller.go:265, master_kode_anggaran_controller.go:26; apb_controller.go:41 & pengeluaran_controller.go:38 (image.Decode)
Endpoint terdampak	GET list endpoints (vendor, directorate, sub-direktorat, apb, pengeluaran, penerimaan, kode-anggaran); POST /apb/create; PUT /apb/:id; PUT /pengeluaran/:id; POST /penerimaan/create; PUT /penerimaan/update/:id
Prasyarat	Token valid.
Dampak (C/I/A)	A: Medium-High — gangguan layanan. C/I: None.

Bukti (disamarkan)

```
limit := ctx.QueryInt("limit", 10)
if limit < 1 { limit = 10 }          // tidak ada batas atas (helper pagination umum membatasi 2000, handler ini tidak)

img, _, err := image.Decode(bytes.NewReader(data))   // tanpa image.DecodeConfig / batas piksel
```

Skenario eksploitasi

limit=10000000 memaksa query & serialisasi seluruh tabel. PNG kecil (<1MB) dengan dimensi sangat besar (decompression bomb) dapat memaksa alokasi memori puluhan GB saat image.Decode sehingga pod OOM. Tidak ada rate limiting di level aplikasi (tidak diketahui apakah gateway menyediakannya).

Rekomendasi

Batasi limit (mis. maks 100/500); cek image.DecodeConfig sebelum decode dan tolak bila width*height melebihi batas (mis. 40 MP); set fiber.Config{BodyLimit} eksplisit; terapkan rate limiting di gateway atau middleware limiter.

Contoh perbaikan minimal

```
cfg, _, err := image.DecodeConfig(bytes.NewReader(data))
if err != nil || cfg.Width*cfg.Height > 40_000_000 { return nil, errors.New("dimensi gambar terlalu besar") }
```

Test regresi

Test: limit=100000 -> dibatasi; upload PNG 20000x20000 -> 400 tanpa alokasi besar.

FIN-14 — Secret di-bake ke image container dan token GitLab sebagai build-arg

Severity / Confidence	**Medium** High | Prioritas P1
Kategori	CWE-538 / CWE-214 — API8:2023 Security Misconfiguration
Lokasi	Dockerfile:8-11, 24, 31
Endpoint terdampak	(deployment)
Prasyarat	Akses pull ke registry image atau cache builder.
Dampak (C/I/A)	C: High bila registry/image bocor; I: tergantung secret.

Bukti (disamarkan)

```
ARG GITLAB_USER
ARG GITLAB_TOKEN
RUN git config --global url."https://${GITLAB_USER}:${GITLAB_TOKEN}@scm.alazhar.or.id/"...
COPY config/.env /app/config/.env
COPY --from=builder /app/config/.env /app/config/.env    # final image berisi .env
```

Skenario eksploitasi

Siapa pun yang dapat menarik image dari registry dapat mengekstrak config/.env (JWT secret, DB password, storage key). Token GitLab tersimpan di layer builder/cache build dan riwayat build-arg.

Rekomendasi

Injeksi konfigurasi saat runtime (env var/secret Kubernetes), jangan COPY .env ke image. Gunakan BuildKit secret mount (RUN --mount=type=secret) untuk token GitLab.

Contoh perbaikan minimal

```
# syntax=docker/dockerfile:1.6
RUN --mount=type=secret,id=gitlab_token \
    git config --global url."https://oauth2:$(cat /run/secrets/gitlab_token)@scm.alazhar.or.id/".insteadOf "https://scm.alazhar.or.id/" && go mod
download
# hapus: COPY --from=builder /app/config/.env ...
```

Test regresi

CI: `docker history`/`dive` pada image tidak memuat .env; scan image (trivy --scanners secret).

FIN-15 — Koneksi database dengan sslmode=disable hardcoded

Severity / Confidence	Low High | Prioritas P3
Kategori	CWE-319 — API8:2023 Security Misconfiguration
Lokasi	infrastructure/postgres/client.go:95
Endpoint terdampak	(infrastruktur)
Prasyarat	Posisi di jaringan antara service dan DB.
Dampak (C/I/A)	C/I: Low-Medium tergantung topologi jaringan (tidak diverifikasi).

Bukti (disamarkan)

```
"host=%s user=%s password=%s dbname=%s port=%d sslmode=disable search_path=%s",
```

Skenario eksploitasi

Bila DB berada di jaringan berbeda/bersama, kredensial & data finansial dapat disadap. Konfigurasi DB.SSL di config tidak dipakai pada DSN ini.

Rekomendasi

Gunakan nilai cfg.SSL (require/verify-full) dari konfigurasi, default verify-full di non-lokal.

Contoh perbaikan minimal

```
fmt.Sprintf("host=%s ... sslmode=%s ...", ..., cfg.SSL, ...)
```

Test regresi

Test unit buildDsn: sslmode mengikuti konfigurasi.

FIN-16 — CORS wildcard dan tidak ada security headers

Severity / Confidence	Low High | Prioritas P3
Kategori	CWE-942 / CWE-693 — API8:2023 Security Misconfiguration
Lokasi	infrastructure/rest/server.go:63-69
Endpoint terdampak	(global)
Prasyarat	-
Dampak (C/I/A)	Low — hardening.

Bukti (disamarkan)

```
app.Use(cors.New(cors.Config{ AllowOrigins: "*", AllowCredentials: false, ... }))
// tidak ada helmet / X-Content-Type-Options / Cache-Control: no-store
```

Skenario eksploitasi

Karena autentikasi memakai header Authorization (bukan cookie) dan AllowCredentials=false, wildcard CORS tidak langsung memungkinkan CSRF/pencurian data. Namun origin mana pun dapat memanggil API bila token bocor di sisi klien, dan respons data keuangan dapat ter-cache oleh proxy/browser.

Rekomendasi

Batasi AllowOrigins ke domain frontend resmi; tambahkan middleware helmet dan Cache-Control: no-store untuk respons API.

Contoh perbaikan minimal

```
app.Use(helmet.New())
app.Use(cors.New(cors.Config{AllowOrigins: "https://dev-fintech.alazhar.or.id, https://fintech.alazhar.or.id"}))
```

Test regresi

Test: preflight dari origin tak dikenal tidak mendapat Access-Control-Allow-Origin.

FIN-17 — Ekstensi file upload (PDF) diambil dari nama file klien

Severity / Confidence	**Low** High | Prioritas P3
Kategori	CWE-434 — API8:2023
Lokasi	presentation/controller/apb_controller.go:212; pengeluaran_controller.go:102; penerimaan_controller.go:141
Endpoint terdampak	POST /apb/create; PUT /apb/:id; PUT /pengeluaran/:id; POST /penerimaan/create; PUT /penerimaan/update/:id
Prasyarat	Token valid.
Dampak (C/I/A)	Low.

Bukti (disamarkan)

```
detectedType := http.DetectContentType(fileBytes)   // validasi isi: baik
fileExtension := filepath.Ext(file.Filename)        // ekstensi dari klien untuk PDF
fileName := uuid.NewString() + fileExtension
```

Skenario eksploitasi

File berawalan %PDF- dengan nama 'x.html' tersimpan sebagai <uuid>.html. Content-Type objek diset application/pdf saat upload sehingga risiko XSS rendah, namun bergantung pada konfigurasi storage/CDN saat menyajikan file.

Rekomendasi

Tentukan ekstensi dari detectedType (application/pdf -> .pdf), abaikan nama file klien.

Contoh perbaikan minimal

```
ext := map[string]string{"application/pdf": ".pdf", "image/jpeg": ".jpg", "image/png": ".jpg"}[detectedType]
```

Test regresi

Test: upload PDF bernama x.html -> objek tersimpan .pdf.

FIN-18 — Daftar pengguna (id, nama, role level) dapat diakses semua user login

Severity / Confidence	**Low** Medium | Prioritas P3
Kategori	CWE-200 — API3:2023 Broken Object Property Level Authorization
Lokasi	infrastructure/rest/route.go:49; domain/repository/sub_directorate_repository.go:195-200
Endpoint terdampak	GET /dropdown/users
Prasyarat	Token valid.
Dampak (C/I/A)	C: Low.

Bukti (disamarkan)

```
Select("u.id, u.name, MIN(uhr.role_level_id) AS role_level_id").
Where("uhr.role_level_id IN ?", []int{1, 2, 3, 11, 20, 21, 22})
```

Skenario eksploitasi

User biasa memperoleh daftar user_id + nama + level role, yang mempermudah penargetan (mis. memalsukan token dengan user_id admin bila FIN-01 dieksploitasi).

Rekomendasi

Batasi ke role admin/pengelola sub-direktorat (RequirePermission).

Contoh perbaikan minimal

```
dropdown.Get("/users", middleware.RequirePermission(middleware.MenuMasterSubdir), subDirectorateController.UserDropdownHandler)
```

Test regresi

Test: role non-admin -> 403.

FIN-19 — Default Locals role_level_id=1 untuk semua request & route terdaftar dua kali

Severity / Confidence	**Informational** High | Prioritas P3
Kategori	CWE-1188 — API8:2023
Lokasi	infrastructure/rest/server.go:80-83; server.go:86 & cmd/main.go (RegisterRoutes dipanggil dua kali)
Endpoint terdampak	(global)
Prasyarat	-
Dampak (C/I/A)	Informational (risiko laten).

Bukti (disamarkan)

```
app.Use(func(c *fiber.Ctx) error { c.Locals("role_level_id", 1); return c.Next() })
// Auth hanya menimpa bila klaim ada di token -> token tanpa role_level_id mewarisi nilai 1
```

Skenario eksploitasi

Saat ini role_level_id tidak dipakai untuk keputusan otorisasi (diverifikasi via grep), sehingga belum dapat dieksploitasi. Bila kelak dipakai, token tanpa klaim tersebut otomatis mendapat level 1 (kemungkinan level tertinggi). Pendaftaran route ganda menambah kompleksitas middleware chain.

Rekomendasi

Hapus middleware default role_level_id; panggil RegisterRoutes hanya sekali.

Contoh perbaikan minimal

```
// hapus blok app.Use(... c.Locals("role_level_id", 1) ...)
```

Test regresi

Test: route count == jumlah route unik.

6. Prioritas remediasi

P0 — Segera (hari ini – 3 hari): eksposur langsung / dapat dieksploitasi dengan prasyarat minimal.

- **FIN-01** JWT signing secret & kredensial lain pernah di-commit ke git dan masih dipakai (Critical)
- **FIN-02** Endpoint laporan realisasi anggaran tanpa autentikasi (High)
- **FIN-03** SQL injection pada parameter sortColumn/sortOrder (ORDER BY) (High)

P1 — 1–2 minggu: kontrol akses & integritas alur keuangan.

- **FIN-04** Tidak ada otorisasi berbasis role (function-level) selain /settings (High)
- **FIN-05** Pembatasan data per subdirektorat ditentukan oleh parameter klien (BOLA/IDOR) (High)
- **FIN-06** Persetujuan kegiatan (RAPB) tanpa validasi transisi status dan tanpa row lock (High)
- **FIN-07** Mass assignment pada update APB: nominal pencairan dan URL dokumen dapat diisi bebas (High)
- **FIN-14** Secret di-bake ke image container dan token GitLab sebagai build-arg (Medium)

P2 — 2–6 minggu: hardening alur bisnis, ketersediaan, dan observabilitas.

- **FIN-08** Status penerimaan ditentukan klien (dapat langsung 'settled') (Medium)
- **FIN-09** Hard delete data keuangan tanpa cek status dan tanpa audit trail (Medium)
- **FIN-10** Pesan error internal/database dikembalikan ke klien (Medium)
- **FIN-11** Pencabutan token (blacklist) fail-open saat Redis tidak tersedia (Medium)
- **FIN-13** Potensi resource exhaustion: limit tanpa batas atas, decode gambar tanpa batas dimensi, tanpa rate limit (Medium)

P3 — Backlog terjadwal: hardening & kebersihan konfigurasi.

- **FIN-12** Validasi JWT kurang ketat (algoritma, iss/aud, exp wajib) dan parsing ganda v4/v5 (Low)
- **FIN-15** Koneksi database dengan sslmode=disable hardcoded (Low)
- **FIN-16** CORS wildcard dan tidak ada security headers (Low)
- **FIN-17** Ekstensi file upload (PDF) diambil dari nama file klien (Low)
- **FIN-18** Daftar pengguna (id, nama, role level) dapat diakses semua user login (Low)
- **FIN-19** Default Locals role_level_id=1 untuk semua request & route terdaftar dua kali (Informational)

7. Hasil tool scanning dan keterbatasannya

Waktu eksekusi tool: 2026-10-25 15:52:07 WIB (lokal, macOS arm64).

Tool	Versi	Status	Hasil
go vet ./...	go1.25.0 darwin/arm64	Selesai, exit 0	Tidak ada temuan.
go test ./...	go1.25.0	Selesai, exit 0	6 paket lulus; paket lain tidak memiliki test. Test yang ada bersifat fungsional, bukan security test.
staticcheck ./...	2025.1.1 (0.6.1)	Tidak dapat dijalankan	Binary dibangun dengan go1.24.6 sementara modul memerlukan go1.25.0. Perlu rebuild staticcheck dengan Go 1.25.
govulncheck ./...	-	Tidak dijalankan	Tidak terpasang; instalasi memerlukan unduhan jaringan dan belum disetujui. Instruksi: go install golang.org/x/vuln/cmd/govulncheck@latest
gosec ./...	-	Tidak dijalankan	Tidak terpasang; instalasi memerlukan unduhan jaringan dan belum disetujui. Instruksi: go install github.com/securego/gosec/v2/cmd/gosec@latest
Secret scan lokal (grep pola + git history)	manual	Selesai	Tidak ada secret hardcoded pada file yang ter-track saat ini. git history memuat .env/config/.env (FIN-01). Nilai tidak ditampilkan.
Dynamic testing	-	Tidak dijalankan	Database lokal (port 5433) tidak tersedia dan tidak ada persetujuan untuk menguji server dev/staging. Semua temuan berasal dari analisis statis; bukti dinamis satu-satunya adalah respons error yang ditunjukkan user (FIN-10).

> Tidak ada scanner otomatis yang menjalankan analisis keamanan pada audit ini; seluruh temuan berasal dari review manual. Hasil go vet/go test yang bersih tidak menunjukkan apa pun tentang keamanan. govulncheck (CVE dependency) dan gosec perlu dijalankan sebelum retest.

8. Kesimpulan dan rencana retest

Risiko terbesar saat ini adalah kombinasi **secret JWT yang bocor** (FIN-01) dengan **ketiadaan otorisasi role/kepemilikan** (FIN-04, FIN-05): bila secret tersebut juga dipakai di server dev/prod, penyerang dengan akses repo memiliki kendali penuh atas data keuangan. Endpoint laporan anonim (FIN-02) dan SQL injection ORDER BY (FIN-03) dapat diperbaiki dalam hitungan jam dan sebaiknya dilakukan bersamaan dengan rotasi secret.

1. **Retest 1 (setelah P0):** verifikasi token yang ditandatangani secret lama ditolak; GET /laporan/* tanpa token = 401; payload ORDER BY tidak mengubah query.
2. **Retest 2 (setelah P1):** test matriks role x endpoint, test scope subdirektorat (akses lintas unit = 403/404), test state machine kegiatan & APB, image tanpa .env.
3. **Retest 3 (setelah P2/P3):** govulncheck, gosec, staticcheck (Go 1.25) di CI; dynamic testing terbatas di staging dengan akun dummy dan data sintetis, setelah persetujuan.